Fundamentals of Cybersecurity

Mohammad Hosseini

Faculty of Computer Science and Engineering
Shahid Beheshti University

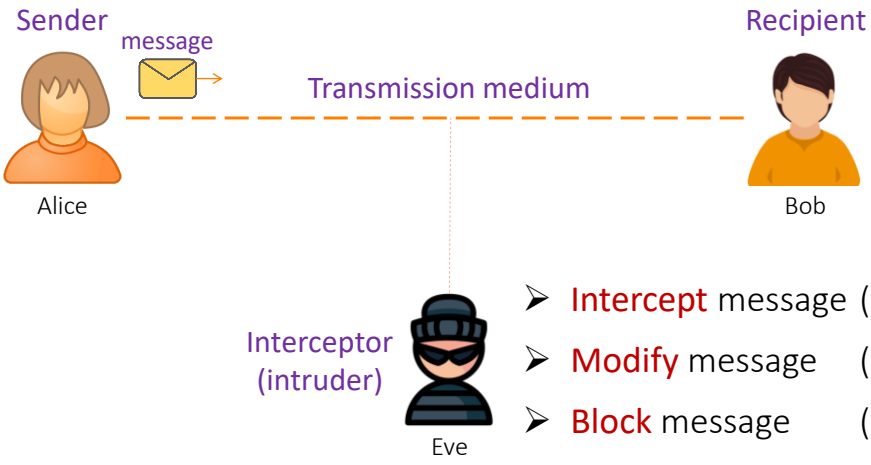
Security Toolbox

Part2:

Cryptography



Problem



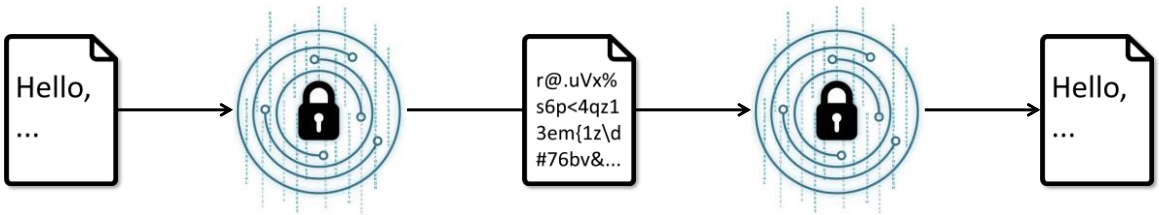
- Intercept message (violating confidentiality)
- Modify message (violating integrity)
- Block message (violating availability)

Encryption is a means of maintaining secure data in an insecure environment.

Terms and concepts

- Encryption: the process of encoding a message so that its meaning is not obvious.
- Decryption: transforming an encrypted message back into its normal, original form.
- Cryptography: the field of designing, analyzing, and using algorithms for encryption and decryption.
- Plaintext: the original (intelligible) form of a message.
- Ciphertext: the encrypted form of a message.

Encryption



Plaintext → Encryption algorithm → Ciphertext (scrambled data) → Decryption algorithm → Plaintext

Secrecy in encryption

The encryption and decryption algorithms often use a key.

- The resulting ciphertext depends on the original plaintext message, the algorithms, and the key value.
- It is better to have a few well-examined encryption algorithms for everyone to use, but differing keys prevent someone from breaking into protected data.

$$C = E(K, P)$$

ciphertext; encryption algorithm; key; plaintext

$$P = D(K, C)$$

decryption algorithm

Secrecy in encryption

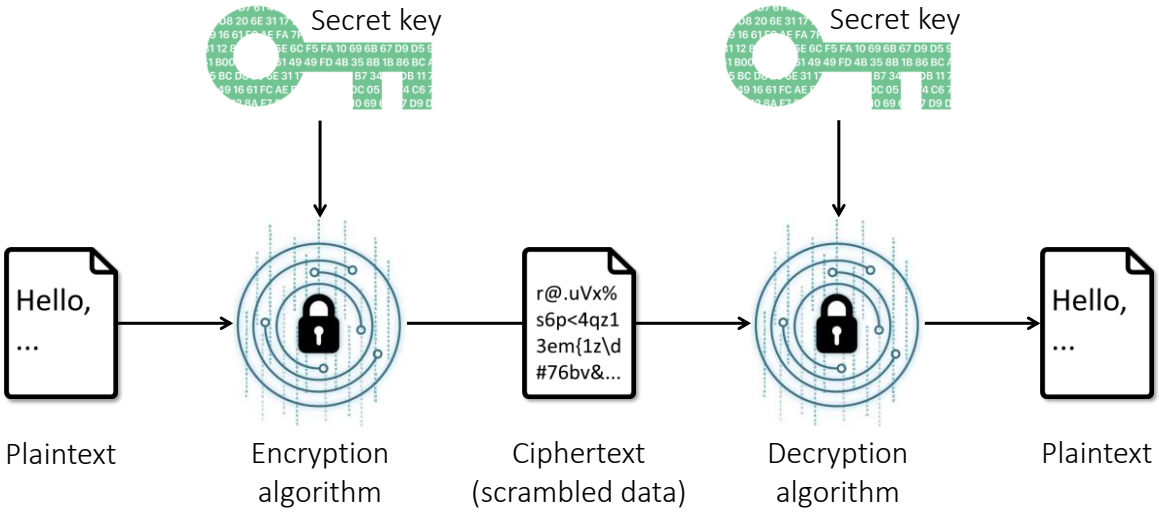
The security of encryption depends on the secrecy of the key, not the secrecy of the algorithm.

- Moreover, we can have low-cost chip implementations of data encryption algorithms.

The encryption algorithm must be **strong**.

- An opponent who knows the algorithm would be unable to decipher the ciphertext or figure out the key.

Encryption



Number of keys

Symmetric encryption

(single-key encryption)
(secret-key encryption)

Both sender and receiver use the same key

encryption/decryption key

$$P = D(K, E(K, P))$$

Asymmetric encryption

(two-key encryption)
(public-key encryption)

Sender and receiver each use a different key

encryption key + decryption key

$$P = D(K_d, E(K_e, P))$$

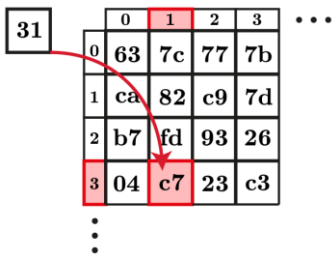
A trivial example of encryption

- Shift each plaintext letter forward **n** positions in the alphabet

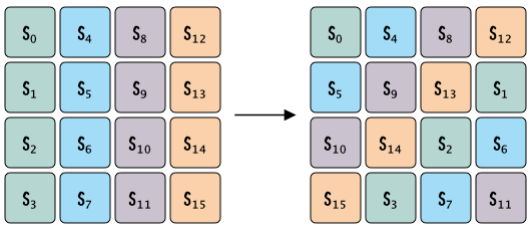
Internal operations of encryption algorithms

All encryption algorithms are based on two general principles:

- Substitution: each element (e.g., each byte) is mapped into another element.

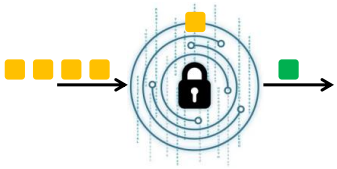


- Transposition: elements are rearranged.

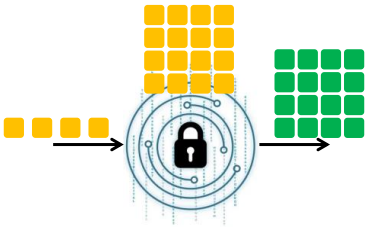


Processing way of plaintext

- Stream cipher: processes the input elements continuously, producing output one element at a time, as it goes along.
  - It can be applied immediately to whatever data items are ready to transmit.
  - Low error propagation



- Block cipher: processes the input one block of elements at a time, producing an output block for each input block.
  - Harder to be broken (high diffusion)
  - Blocks for such algorithms are typically 64, 128, 256 bits or more.



Cryptanalysis

Cryptanalysis: the process of attempting to discover the plaintext or key.

Type of attack	Known to cryptanalyst
Ciphertext only	• Encryption algorithm • Ciphertext to be decoded • ?
Known plaintext	• Encryption algorithm • Ciphertext to be decoded • One or more plaintext–ciphertext pairs formed with the secret key
Chosen plaintext	• Encryption algorithm • Ciphertext to be decoded • Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key
Chosen ciphertext	…
Chosen text	…

Cryptanalysis

So, what's the best way to encrypt a file?



Cryptanalysis

An encryption scheme is computationally secure if the ciphertext generated by the scheme meets one or both of the following criteria:

- The cost of breaking the cipher exceeds the value of the encrypted information.
- The time required to break the cipher exceeds the useful lifetime of the information.

➢ The work factor to break the encryption is large enough to deter most attacks.

Cryptanalysis

How to estimate the amount of effort required to cryptanalyze ciphertext successfully?

- Assuming there are no inherent mathematical weaknesses in the algorithm → only brute-force is applicable

- Brute-force attack: trying every possible key until an intelligible translation of the ciphertext into plaintext is obtained.
  - On average, half of all possible keys must be tried to achieve success.
  - Unless known plaintext is provided, the analyst must be able to recognize plaintext as plaintext.

Symmetric encryption

DES

Data Encryption Standard (DES)

- Developed in the 1970s (standardized by NIST)
- Symmetric encryption algorithm
- Block cipher (block size: 64 bits)
- Key size: 56 bits
- Today, DES is insecure due to the relatively short key size.
  - 2^{56} possible keys (7.2×10^{16})
- **Triple DES**: three executions of the DES algorithm with three 56-bit keys (gives strength equivalent to about 112-bit key)

Drawbacks of triple DES

- The algorithm is relatively sluggish in software.
- For reasons of both efficiency and security, the 64-bit block size is not satisfactory.
  - As a replacement, NIST in 1997 issued a call for proposals for a new **Advanced Encryption Standard (AES)**, which should have a security strength equal to or better than 3DES and significantly improved efficiency.
    - ✓ **Evaluation criteria**: security, computational efficiency, memory requirements, hardware and software suitability, and flexibility.

AES

Advanced Encryption Standard (AES) (original name: Rijndael)

- Developed by *Joan Daemen* and *Vincent Rijmen* (standardized in 2001)
- Symmetric encryption algorithm
- Block cipher (block size: 128 bits)
- Key size: 128/192/256 bits

AES animation …

Average time required for exhaustive key search

Key Size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 Decryptions/s	Time Required at 10^{13} Decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour
128	AES	$2^{128} \approx 3.4 \times 10^{38}$	2^{127} ns = 5.3×10^{21} years	5.3×10^{17} years
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	2^{167} ns = 5.8×10^{33} years	5.8×10^{29} years
192	AES	$2^{192} \approx 6.3 \times 10^{57}$	2^{191} ns = 9.8×10^{40} years	9.8×10^{36} years
256	AES	$2^{256} \approx 1.2 \times 10^{77}$	2^{255} ns = 1.8×10^{60} years	1.8×10^{56} years

Message authentication

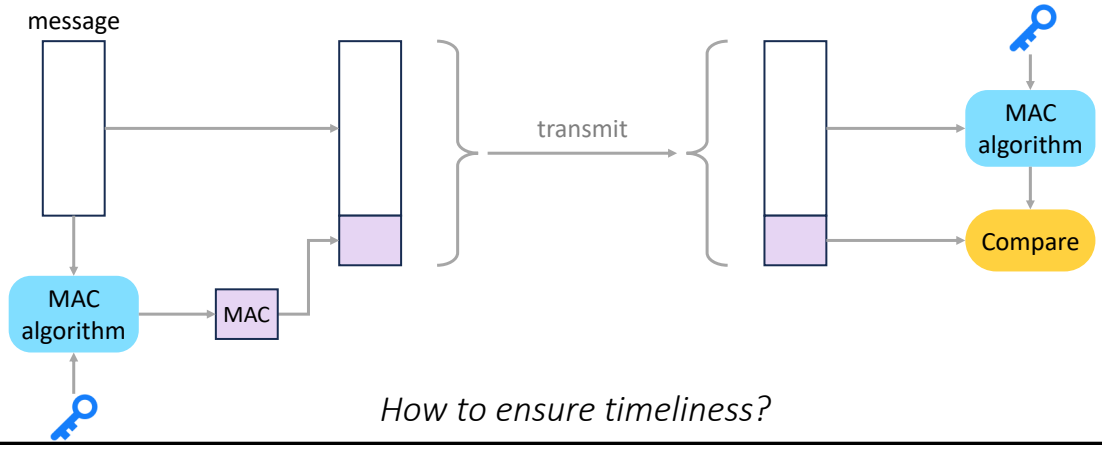
Message authentication

- The encryption we discussed so far protects against **passive attack** (eavesdropping).
- A different requirement is to protect against **active attack**; ensuring the message …
  - has not been altered while in transit (data integrity)
  - comes from an authentic source (authenticity)
  - is recent and not a replay of an old message (timeliness)
- Protection against such attacks is known as message authentication.

Message authentication

Solution: Use a secret key to generate a small block of data, known as a message authentication code (MAC), and append it to the message.

$$MAC_m = F(m, k)$$

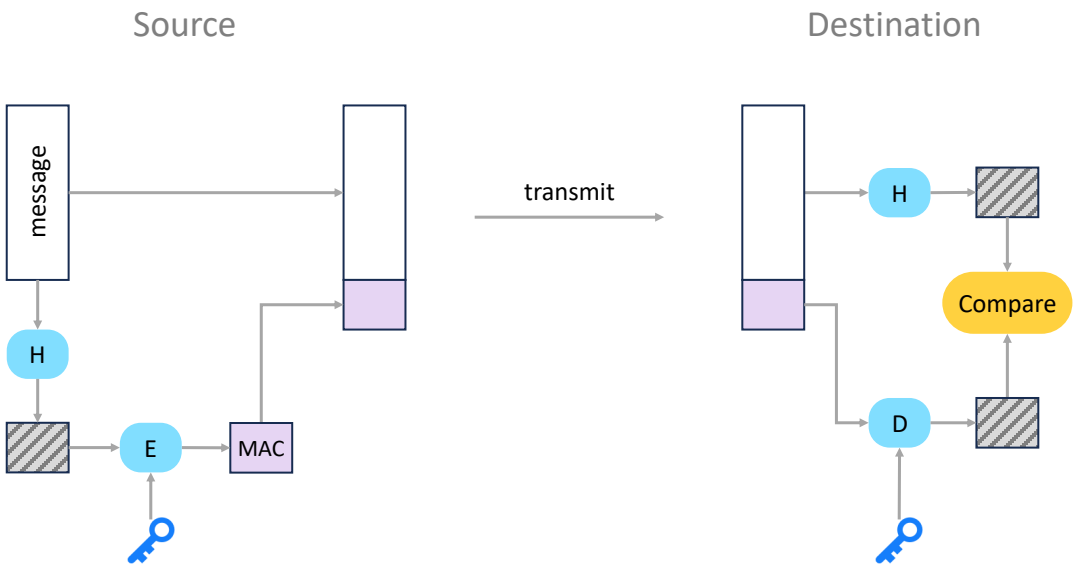


How to ensure timeliness?

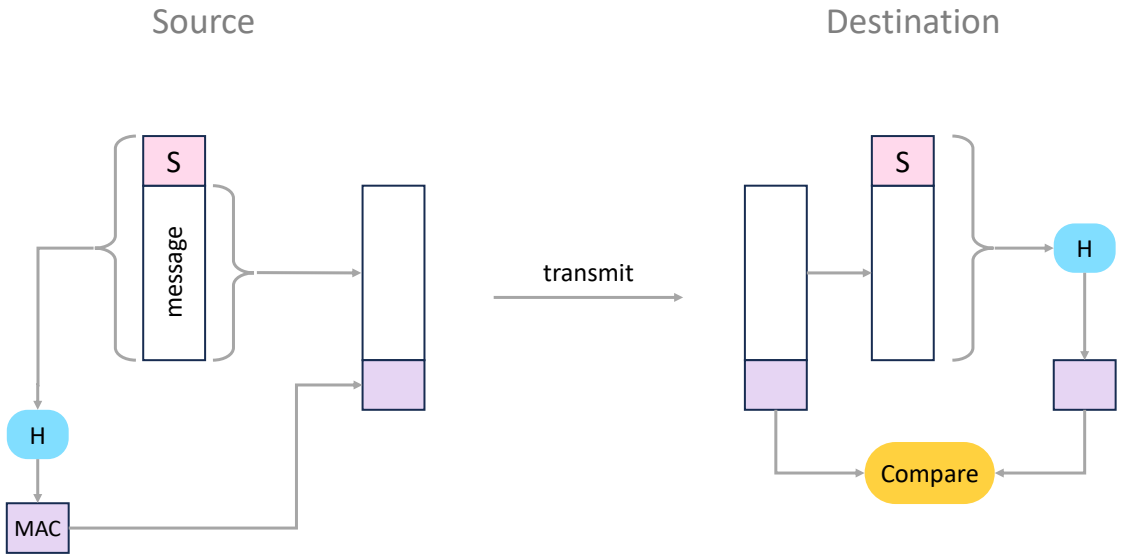
MAC approaches

- Make use of a symmetric encryption algorithm to generate an encrypted version of the message, and use the last number of bits of ciphertext as the code.
  - ➢ Not efficient in case of a large message
- Make use of a one-way hash function.
  - ➢ Less computation

MAC: hash and encryption



MAC: secret value and hash



A variation of this technique, called HMAC, is adopted for IP security.

Secure hash function

To be useful for message authentication, a hash function H must have the following properties:

- easy to compute (for both hardware and software implementations)
- one-way: for any given code h, it is computationally infeasible to find x such that $H(x) = h$ (preimage resistant)
- weak collision resistant: for any given block x, it is computationally infeasible to find $y \neq x$ with $H(y) = H(x)$ (second-preimage resistant)
- (strong) collision resistant: it is computationally infeasible to find any pair (x, y) such that $H(x) = H(y)$

Secure hash function

Two approaches to attacking a secure hash function:

- Cryptanalysis (exploiting logical weaknesses in the algorithm)
- Brute-force attack

➢ The strength of a hash function against brute-force attacks depends on the length of the produced hash code.

The level of brute-force effort required for a hash code of length n:

- Preimage resistant: 2^n
- Second preimage resistant: 2^n
- Collision resistant: $2^{n/2}$ *(Birthday attack)*

Some secure hash functions

- MD5 [1991] 128-bit hash not secure anymore
- SHA-1 [1995] 160-bit hash
- SHA-2 [2001] SHA-256: 256-bit hash SHA-512: 512-bit hash

HMAC

A hash function such as SHA-1 was not designed for use as a MAC and cannot be used directly for that purpose because it does not rely on a secret key.

❖ Hash-based message authentication code (HMAC) (RFC 2104)

- Combines a cryptographic hash function with a secret key.
- Any cryptographic hash function, such as SHA-2 or SHA-3, may be used in the calculation of an HMAC.

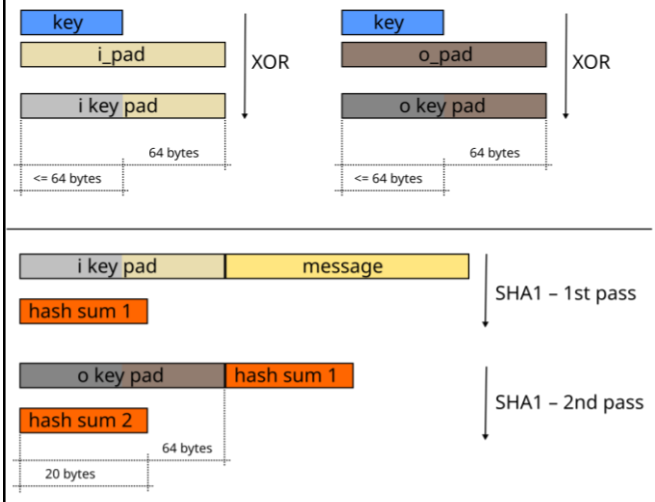
```
HMAC_MD5("key", "The quick brown fox jumps over the lazy dog")    = 80070713463e7749b90c2dc24911e275

HMAC_SHA1("key", "The quick brown fox jumps over the lazy dog")   =
de7c9b85b8b78aa6bc8a7a36f70a90701c9db4d9

HMAC_SHA256("key", "The quick brown fox jumps over the lazy dog") =
f7bc83f430538424b13298e6aa6fb143ef4d59a14946175997479dbc2d1a3cd8

HMAC_SHA512("key", "The quick brown fox jumps over the lazy dog") =
b42af09057bac1e2d41708e48a902e09b5ff7f12ab428a4fe86653c73dd248fb82f948a549f7b791a5b41915ee4d1ec3935357e
4e2317250d0372afa2ebeeb3a
```

HMAC



$$\mathrm{HMAC}(K, m) = \mathrm{H}\left(\left(K' \oplus opad\right) \parallel \mathrm{H}\left(\left(K' \oplus ipad\right) \parallel m\right)\right)$$

$$K' = \begin{cases} \mathrm{H}(K) & \text{if } K \text{ is larger than block size} \\ K & \text{otherwise} \end{cases}$$

H is a cryptographic hash function.

m is the message to be authenticated.

K is the secret key.

K' is a block-sized key derived from the secret key, K; either by padding to the right with 0s up to the block size, or by hashing down to less than or equal to the block size first and then padding to the right with zeros.

$\parallel$ denotes concatenation.

$\oplus$ denotes bitwise exclusive or (XOR).

$opad$ is the block-sized outer padding, consisting of repeated bytes valued 0x5c.

$ipad$ is the block-sized inner padding, consisting of repeated bytes valued 0x36.[3]:§2

Asymmetric encryption

(Public-key cryptography)

Symmetric encryption limitations

What are the limitations of symmetric encryption?

- Key distribution: How do two parties securely share a secret key before communication?
- Scalability: In a network of n users, each pair needs a unique key, resulting in $\frac{n(n-1)}{2}$ keys to manage.
- Authentication: symmetric encryption alone does not provide a way to authenticate the sender (for a connection between previously unknown parties)

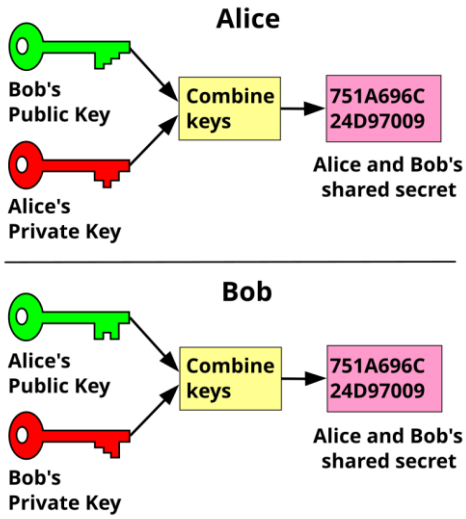
Public-key cryptography

- Invented by Whitfield Diffie and Martin Hellman in 1976.
- Each user has two keys (a pair of related keys), one of which does not have to be kept secret.
  - public key + private key
  - Deducing one key from the other is effectively impossible.
  - Security depends on keeping the **private key** secret.
- Public key encryption systems derive their security from difficult mathematical problems that are computationally hard to solve.

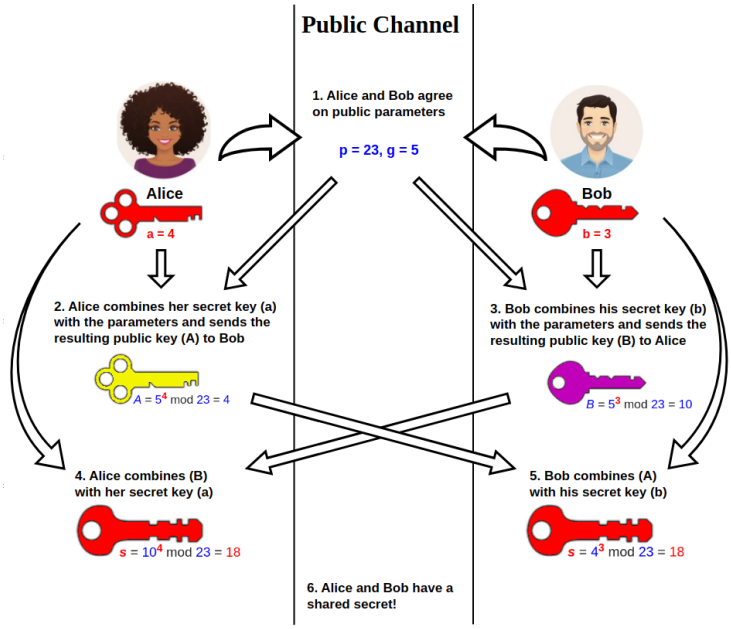
Diffie–Hellman algorithm

- Key exchange algorithm

- Each party generates a public/private key pair and distributes the public key.
- After obtaining an authentic copy of each other's public keys, each party can compute a shared secret offline.
- The shared secret can be used, for instance, as the key for a symmetric cipher.



Diffie–Hellman algorithm



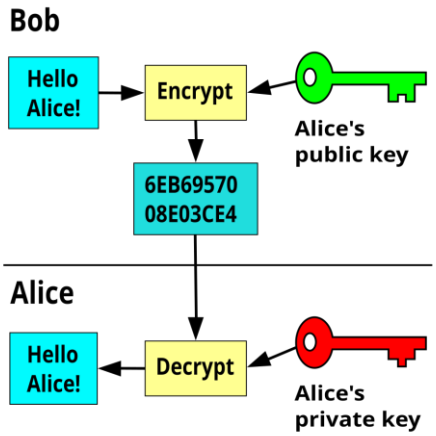
RSA

- Invented by Ron Rivest, Adi Shamir, and Leonard Adleman in 1977.
- Public-key cryptographic system (key generation + encryption + decryption)
- The security of RSA relies on the practical difficulty of factoring the product of two large prime numbers.

$$C = E(K_{Public}, P)$$
$$P = D(K_{Private}, C)$$

Public key encryption with RSA

- Each user generates a pair of keys (public + private) to be used for the encryption and decryption of messages.
- Each user places its public key in a public register or broadcasts the key to the community at large (key announcement).
- If Bob wishes to send a private message to Alice, Bob encrypts the message using Alice's public key.
- When Alice receives the message, she decrypts it using her private key.
  - ➢ No other recipient can decrypt the message because only Alice knows Alice's private key.



RSA

- The number of keys needed in the public key system is only two per user.
- RSA is a relatively slow algorithm.
  - keys are long (2048-,3072-, and 4096-bit keys are widely Used)
  - Encryption is done by exponentiation (raising each plaintext block to the power of key)
  - ➢ It is not commonly used to directly encrypt user data. More often, RSA is used to transmit shared keys for symmetric-key cryptography, which are then used for bulk encryption–decryption.

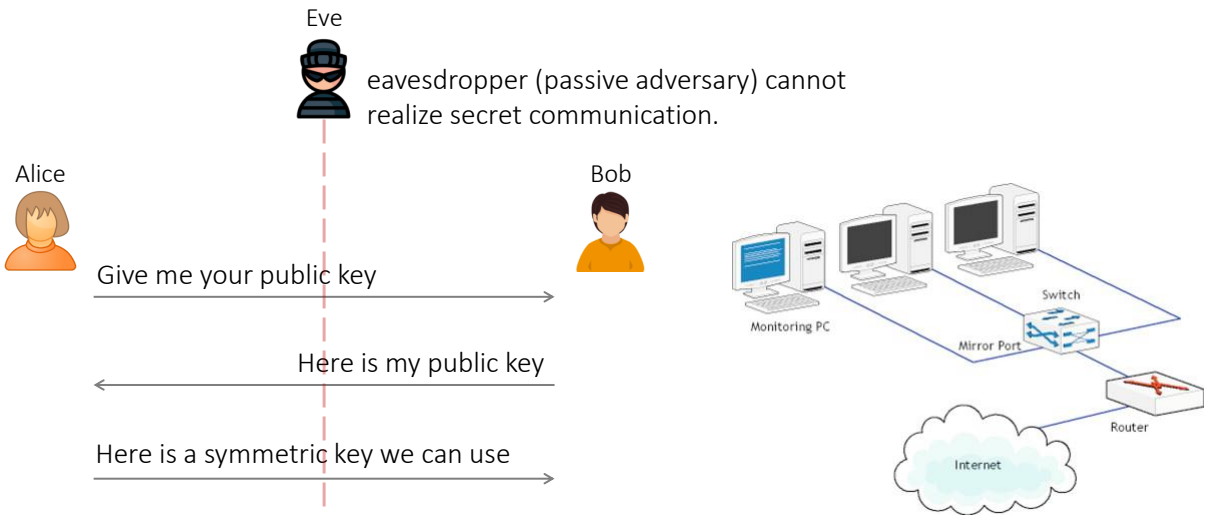
RSA

- With some public key encryption algorithms, including RSA, public and private keys can be applied in either order:

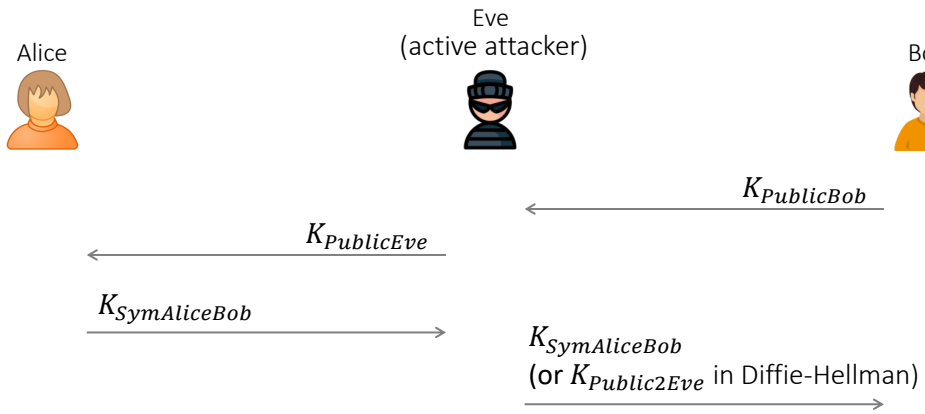
$$P = D(K_{Private}, E(K_{Public}, P))$$ → Application: **public-key encryption**

$$P = D(K_{Public}, E(K_{Private}, P))$$ → Application: **digital signature**

Secure communication with asymmetric encryption



Man-in-the-middle attack



- Asymmetric key exchange (and encryption) protocols are vulnerable to man-in-the-middle attack because they do not authenticate the participants.
- An active attacker can pretend to be Bob and send a public key to Alice or broadcast such a public key.

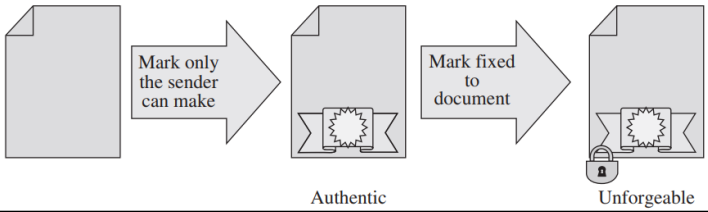
Digital signature
and
Public-key certificate

Signature

- Signature: a mark that only the sender can make, but other people can easily recognize as belonging to the sender.
- Why do we use signatures in our daily activities?
  - Authenticity
  - Nonrepudiation

Digital signature

- Digital signature: a binary object associated with a message and confirms agreement to that message.
- A digital signature must meet two primary conditions:
  - Unforgeable: If person S signs message M with signature $Sig(S, M)$, no one else can produce the pair $[M, Sig(S, M)]$
  - Authentic: If a person R receives the pair $[M, Sig\ (S, M)]$ purportedly from S, R can check that the signature is really from S.

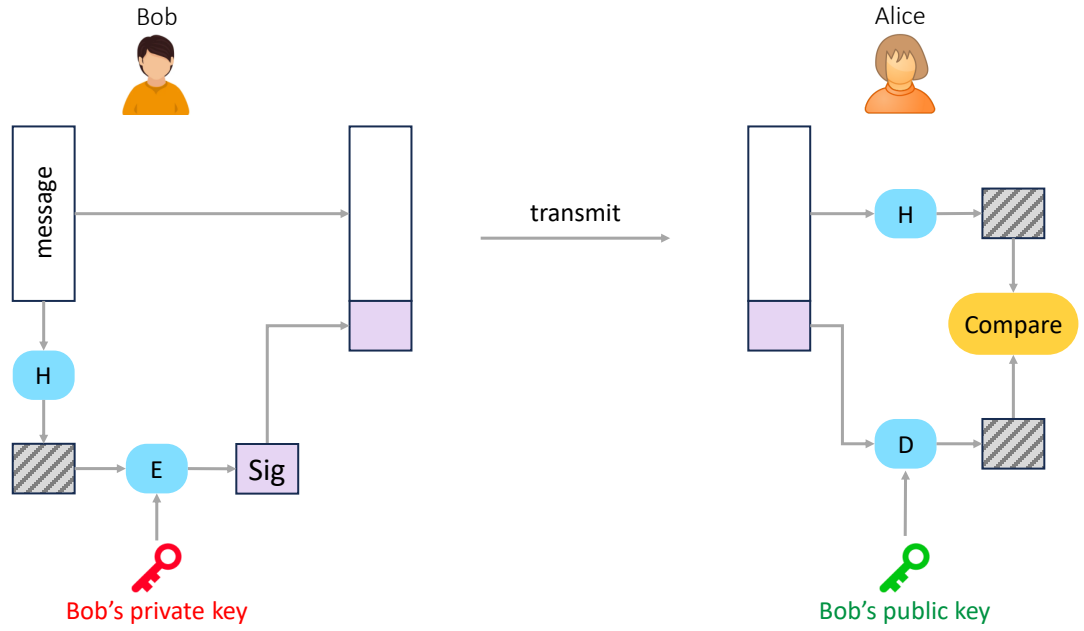


Digital signature

- Two more desirable properties:
  - Not alterable: after being transmitted, M cannot be changed by S, R, or an interceptor.
  - Not reusable: a previous message presented again will be instantly detected by R.

How can we implement digital signature?

Public keys for signatures



Public keys for signatures

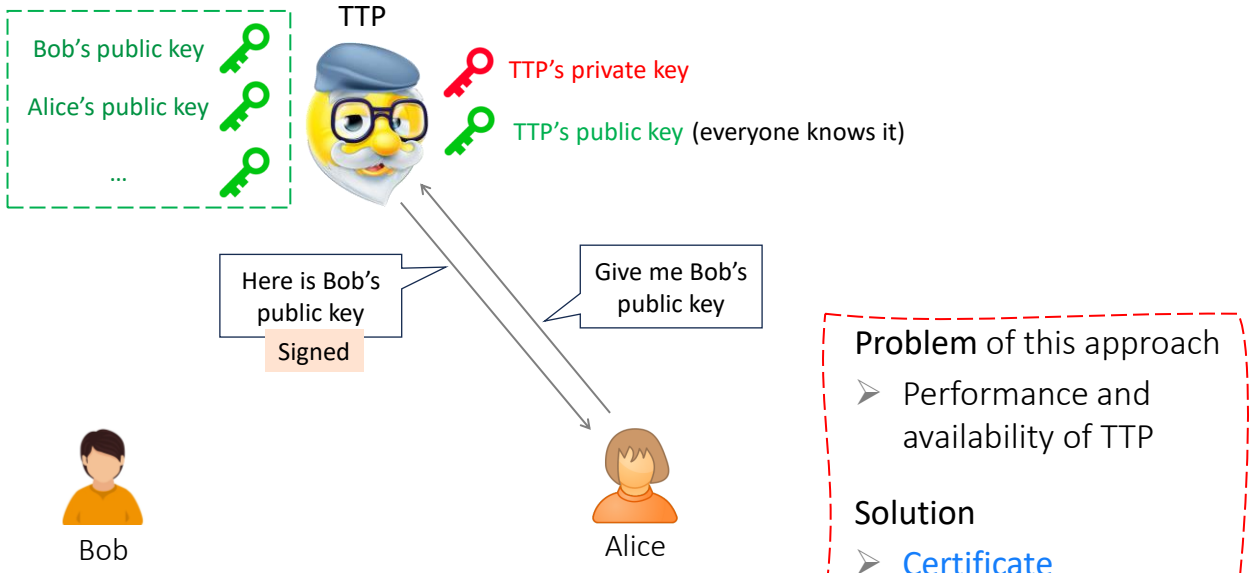
- No one else has Bob's private key and therefore no one else could have created a signature that could be verified for this message with Bob's public key.
- It is impossible to alter the message without access to Bob's private key.
- To add secrecy, Bob can encrypt the whole message using Alice's public key.

The problem of trust

- Problem: if someone says "*this public key belongs to Bob*," on what basis do we believe that assertion?
- In daily life, how do you trust someone you have never met?

Trusted third party

Trusted third party



Problem of this approach

- Performance and availability of TTP

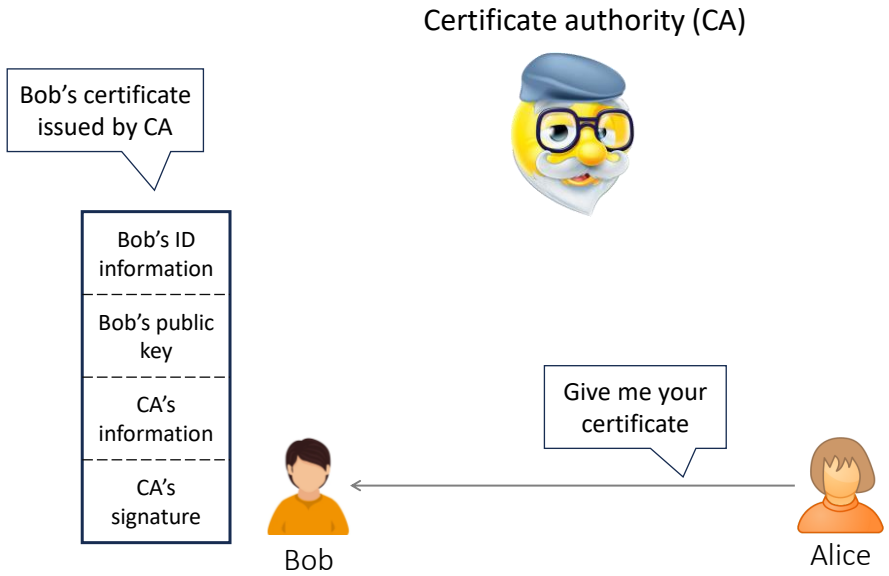
Solution

- Certificate

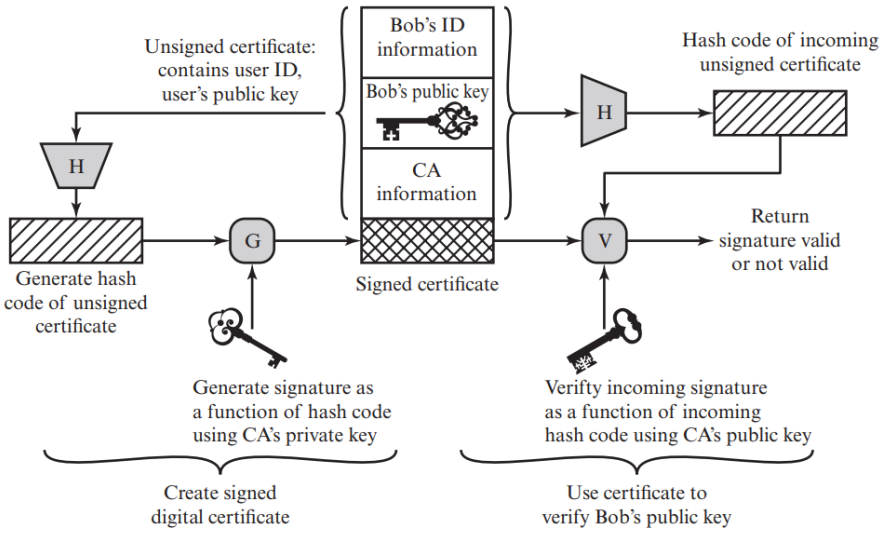
Certificate

- A **certificate** consists of a public key plus a user ID of the key owner, with the whole block signed by a trusted third party.
- The third party is a certificate authority (CA) that is trusted by the user community.
- A user can present his or her public key to the authority in a secure manner and obtain a certificate.
- The user can then publish the certificate.
- Anyone needing this user's public key can obtain the certificate and verify that it is valid by way of the attached trusted signature.

Certificate



Certificate



Certificate

A collection of several companies are designated as root certification authorities

- SecureNet
- VeriSign
- Baltimore Technologies
- Staat der Nederlanden
- Deutsche Telecom
- Entrust
- Certiposte

Browsers and operating systems trust certificates issued by reputable CAs.

Public-key infrastructure (PKI)

- A **public-key infrastructure** (PKI) is a set of tools, roles, rules, and procedures needed to create, manage, distribute, use, store and revoke digital certificates and manage public-key encryption.
- It uses certificates, as we have just described, for exchanging keys with trust.
- A significant use of a PKI is in internet data flow, both messaging and transactions between users and websites

Public-key cryptosystems

Algorithm	Encryption/Decryption	Digital Signature	Key Exchange
RSA	Yes	Yes	Yes
Diffie–Hellman	No	No	Yes
DSS	No	Yes	No
Elliptic curve	Yes	Yes	Yes